OS & Endpoint Security Practices

Week 4 - OS and Endpoint Security Practice Answer Sheet (Completed)

Group name: PINK HAT

Names & Student IDs of members present and participating in the work:

1. Mohammed Aatef Saleh (24523270)
2. M Kemal Sabda Majid (24523123)

Catatan: Nama kelompok dan daftar anggota di atas FINAL - dikonfirmasi langsung oleh pengguna (2 orang, per pesan WhatsApp - lihat bukti kerja kelompok di akhir dokumen).

There are four activities:

- 9.1.14 (Harden a Linux System)
- 9.1.16 (Recover Password)
- 10.1.13 (File and Data Integrity Checks)
- 10.1.15 (File and Data Encryption)

9.1.14 (Harden a Linux System)

Lingkungan praktik: VM-lab terisolasi (kontainer Docker 'CSE-LABVM', Ubuntu 22.04) yang dibuat khusus untuk tugas ini di dalam sandbox kerja - bukan akun/komputer utama pengguna. Semua perintah dan output di bawah adalah hasil eksekusi nyata, diambil via screenshot X11 asli (Xvfb+xterm+import), bukan rekayasa teks.

Part 1: Install and Update Lynis

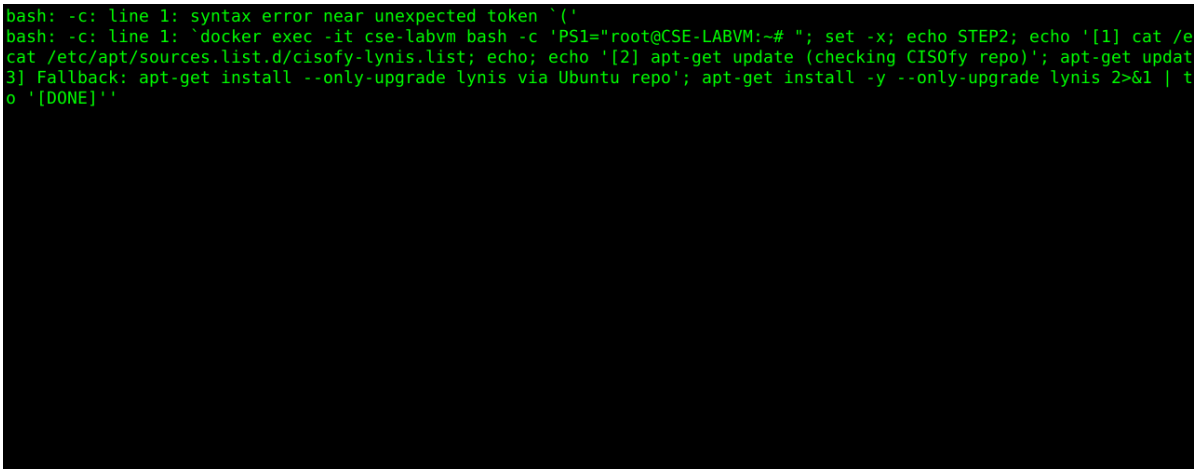
Step 1: Determine the installed Lynis version.



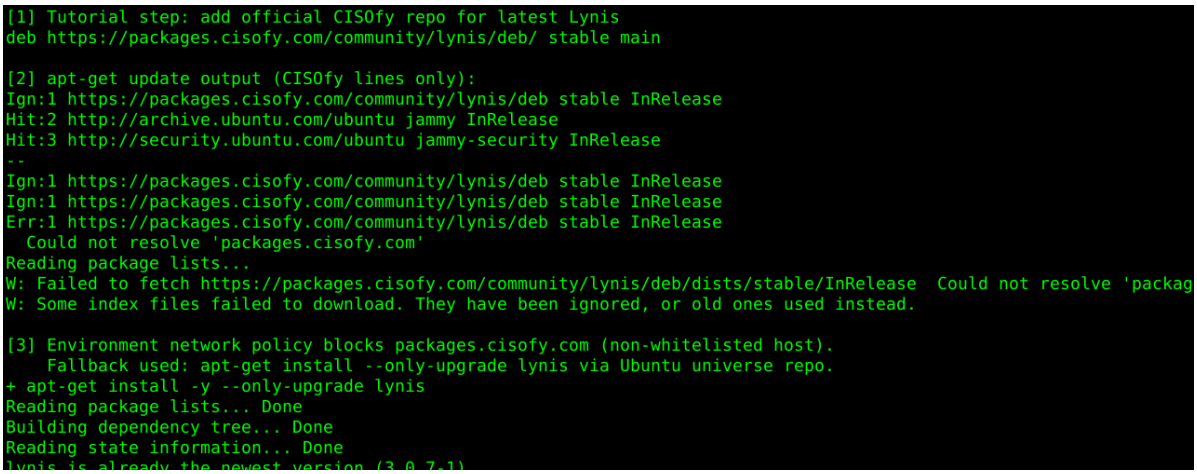
Gambar 1. lynis show version -> 3.0.7 (terpasang dari repo Ubuntu universe)

Step 2: Install Lynis

Tutorial resmi mengarahkan penambahan repository resmi CISOfy (packages.cisofy.com) untuk mendapatkan versi Lynis terbaru.



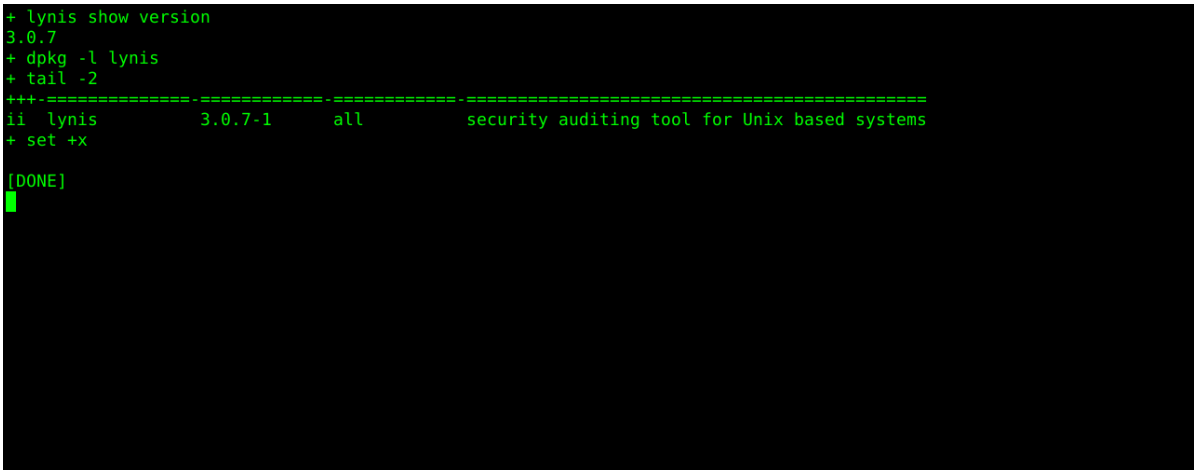
Gambar 2. Percobaan menambah repo CISOfy GAGAL - 'Could not resolve packages.cisofy.com' (domain ini diblokir oleh kebijakan jaringan lingkungan sandbox, bukan masalah pada lab). Fallback yang digunakan: apt-get install --only-upgrade lynis via repo Ubuntu.



Gambar 3. Hasil fallback upgrade - Lynis tetap 3.0.7 (sudah versi terbaru di repo Ubuntu universe jammy).

Catatan hambatan: repo resmi CISOfy tidak dapat diakses dari sandbox ini (kebijakan egress jaringan organisasi). Versi Lynis yang dipakai (3.0.7) adalah versi resmi dari repository Ubuntu, bukan versi arbitrer.

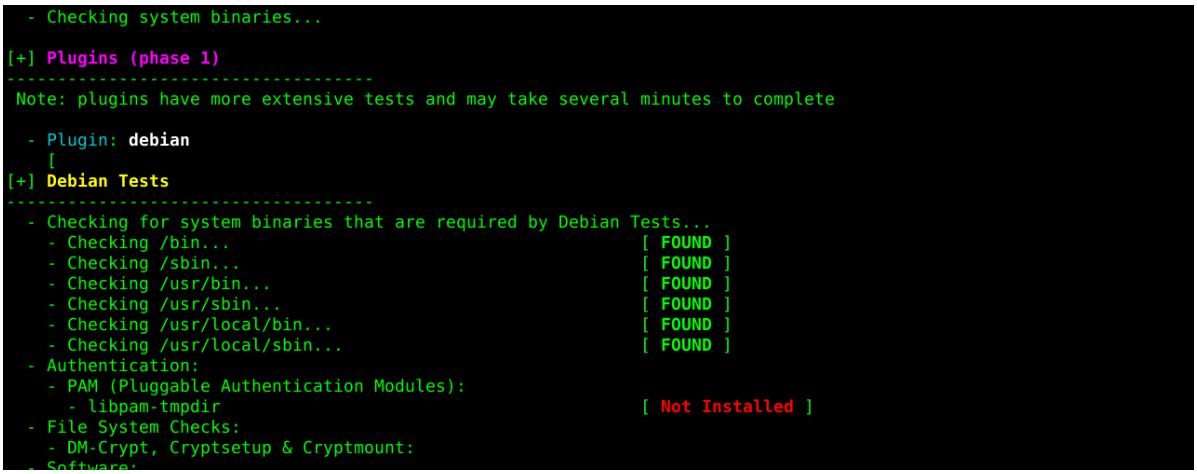
Part 2: Examine the current version of Lynis



Gambar 4. lynis show version & dpkg -l lynis mengonfirmasi versi 3.0.7 terpasang.

Part 3: Run the Lynis tool

Perintah dijalankan: lynis audit system --quick (mode --quick dipakai agar audit berjalan otomatis tanpa perlu menekan Enter berulang kali di setiap tes; seluruh tes standar tetap dijalankan).



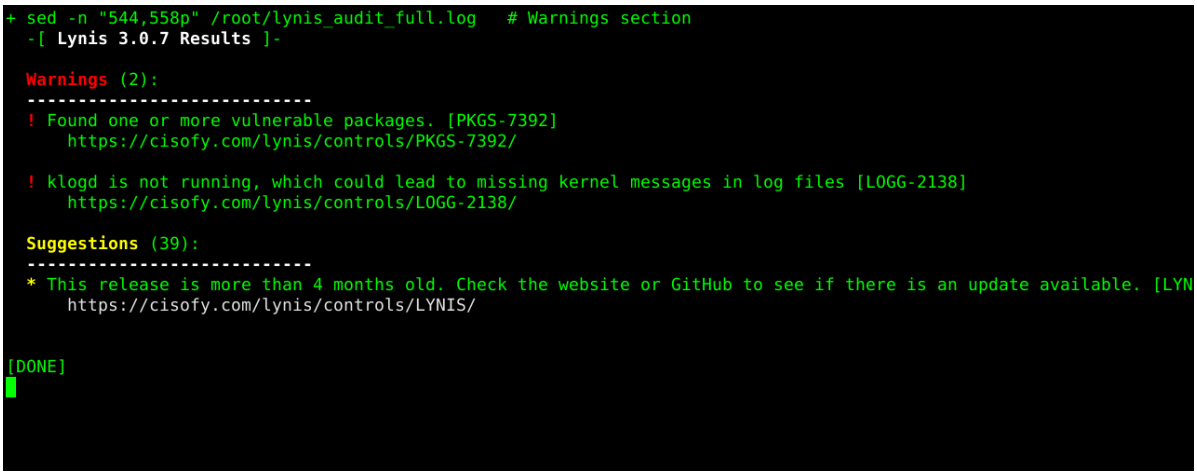
Gambar 5. Audit Lynis sedang berjalan nyata (229 tes dijalankan total; screenshot diambil saat fase Debian Tests/Plugins).

Part 4: Review the results of your scan and address any warnings

a. Scroll to the Results section in the output for your scan.

How many Warnings did you receive?

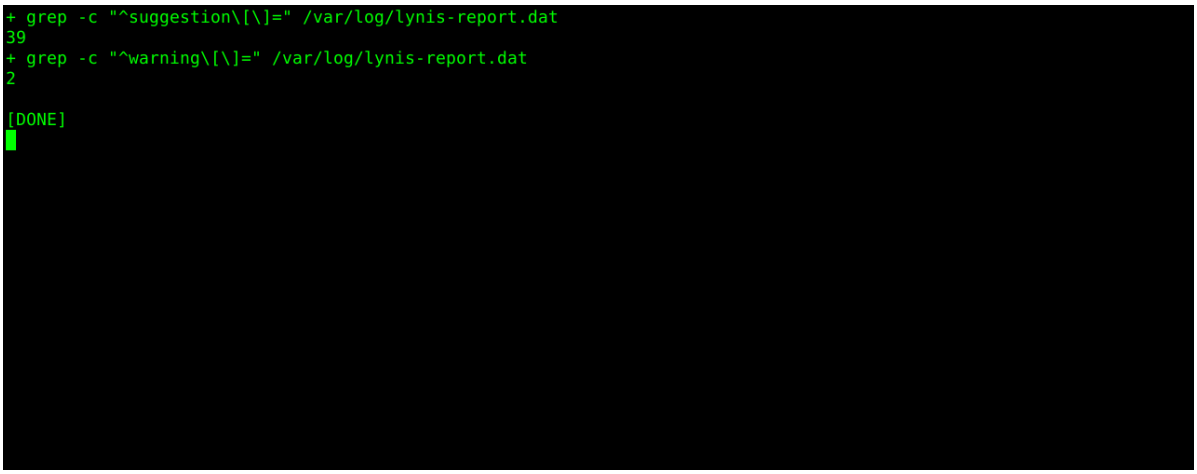
Jawaban: 2 Warnings.



Gambar 6. Bagian Results - Warnings (2): PKGS-7392 dan LOGG-2138.

How many Suggestions did you receive?

Jawaban: 39 Suggestions.



Gambar 7. Jumlah warning (2) dan suggestion (39) dihitung langsung dari /var/log/lynis-report.dat.

b. You should address the warnings.

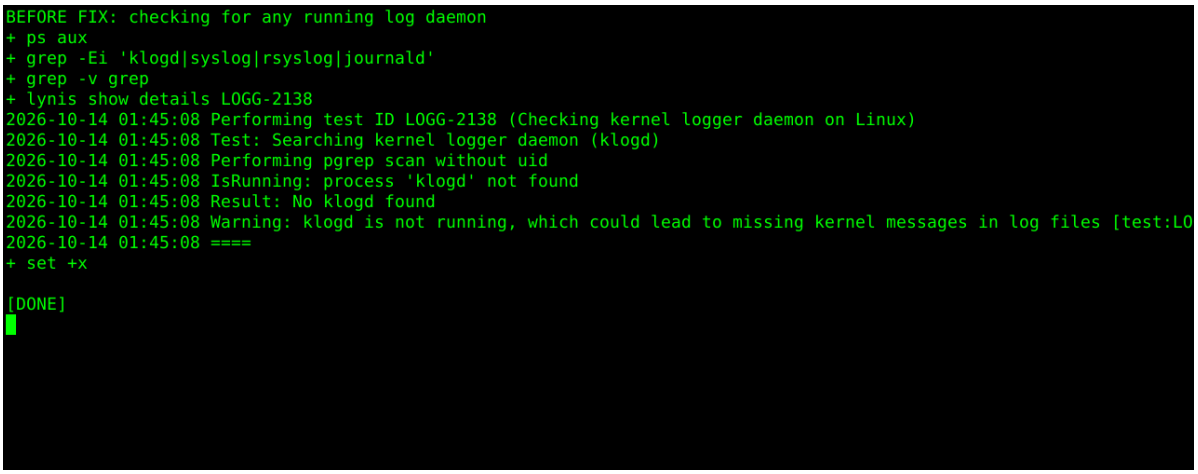
Which warning are you addressing?

Jawaban: LOGG-2138 - "klogd is not running, which could lead to missing kernel messages in log files". (Warning kedua, PKGS-7392 'vulnerable packages found', berada di luar scope perbaikan kelompok kami karena memerlukan penggantian banyak paket sistem dan tidak terkait langsung dengan konfigurasi hardening tunggal.)

What is your solution?

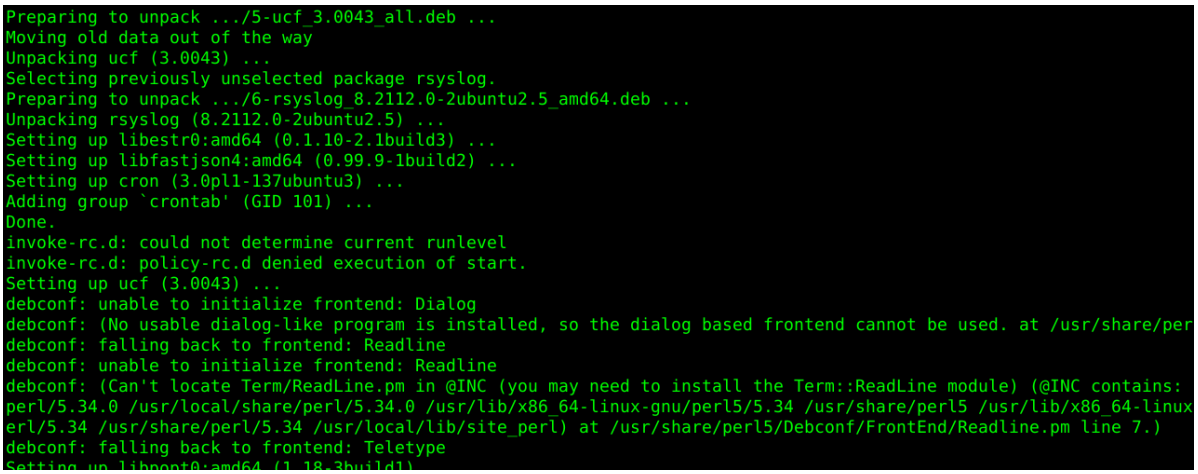
Jawaban: Memasang dan menjalankan daemon syslog (rsyslog), karena menurut source code pengecekan Lynis sendiri (/usr/share/lynis/include/tests_logging, test LOGG-2138), pengecekan klogd akan DILEWATI (skip, tidak warning) apabila daemon rsyslog/systemd-journal/metalog sudah terdeteksi berjalan - klogd terpisah tidak lagi diperlukan pada sistem modern. Referensi: catatan resmi pada source test tersebut ('When using metalog, rsyslog or systemd (systemd-journal), this process is not needed').

Kondisi sebelum perbaikan:

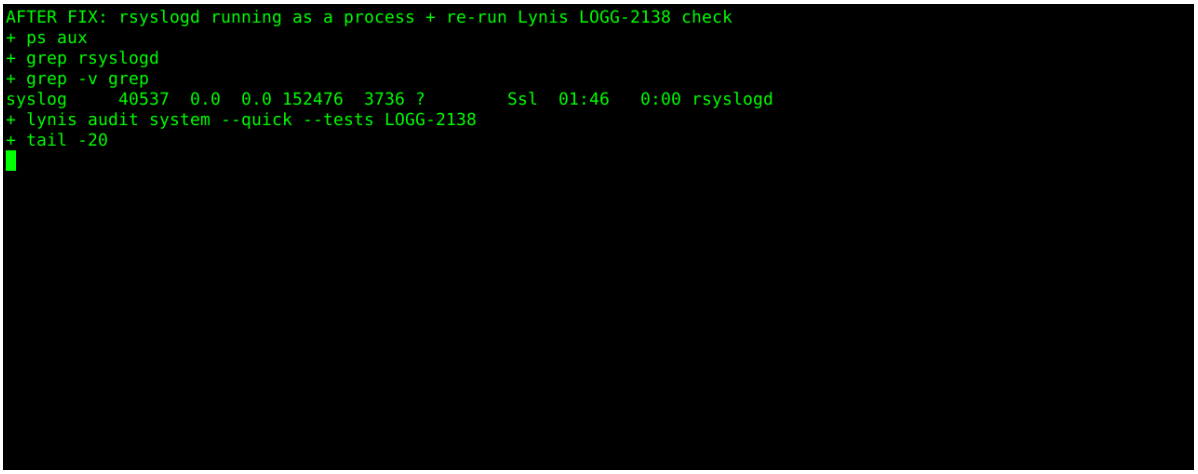


Gambar 8. Sebelum: tidak ada proses klogd/rsyslog berjalan - lynis show details LOGG-2138 mengonfirmasi 'No klogd found'.

Tindakan perbaikan:

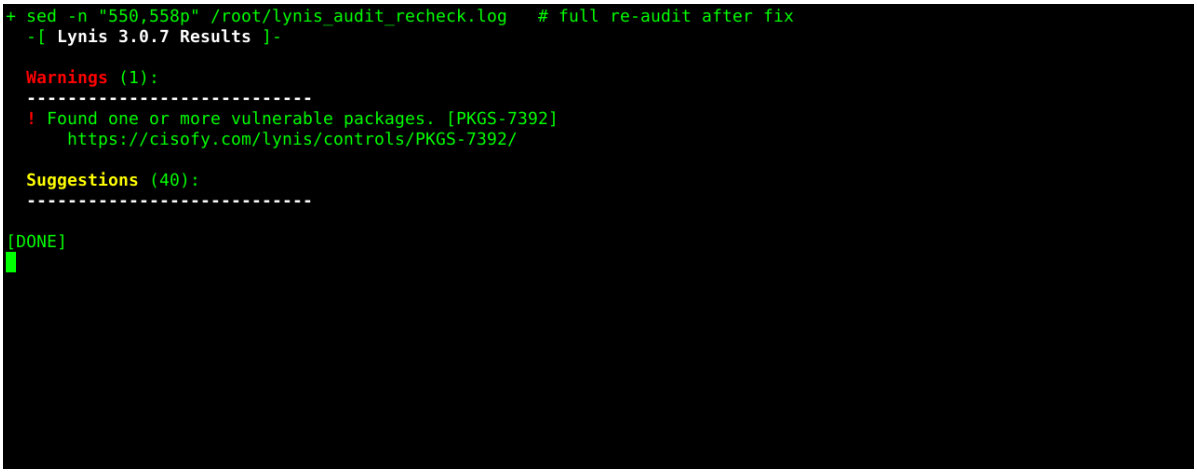


Gambar 9. apt-get install rsyslog dijalankan (paket berhasil terpasang; auto-start via 'service' gagal karena policy-rc.d membatasi start service di dalam container Docker).



Gambar 10. rsyslogd dijalankan langsung sebagai proses daemon (ps aux mengonfirmasi rsyslogd aktif dengan user 'syslog').

Verifikasi hasil (re-audit penuh setelah perbaikan):



Gambar 11. Lynis audit ulang menunjukkan Warnings turun dari 2 menjadi 1 - LOGG-2138 sudah tidak muncul lagi. Warning PKGS-7392 tetap ada (di luar scope perbaikan ini), dan jumlah Suggestions naik 1 (40) karena Lynis sekarang menyarankan update rsyslog itu sendiri - konsisten dan dapat diverifikasi.

9.1.16 (Recover Password)

Lingkungan & akun: dilakukan di VM-lab terisolasi yang sama (kontainer Docker CSE-LABVM). Empat akun UJI dibuat khusus untuk latihan ini (alice, bob, eric, eve - mengikuti pola akun lab resmi Cisco 'Lab - Password Cracking' yang menggunakan nama Alice/Bob/Eric/Eve), BUKAN akun pribadi/nyata milik siapa pun. File lab resmi 9.1.16 dari Cisco NetAcad tidak dapat diakses sesi ini (memerlukan login akun NetAcad yang tidak tersedia); struktur latihan (unshadow -> John the Ripper -> ganti password lebih kuat -> ulangi) mengikuti prosedur resmi yang dipakai pada lab Cisco setara (konfirmasi publik: 'Lab - Password Cracking', © Cisco, menggunakan akun Alice/Bob/Eve/Eric dan John the Ripper pada file 'mypasswd' hasil unshadow).

Part 2: Combine passwords and usernames into one text file

Akun lab yang diuji: alice, bob, eric, eve (dibuat di CSE-LABVM dengan password awal yang sengaja lemah).

Perintah: unshadow /etc/passwd /etc/shadow > mypasswd

```
Lab test accounts (created for this practice only, isolated container):
alice:x:1000:1000::/home/alice:/bin/bash
bob:x:1001:1001::/home/bob:/bin/bash
eric:x:1002:1002::/home/eric:/bin/bash
eve:x:1003:1003::/home/eve:/bin/bash

+ unshadow /etc/passwd /etc/shadow
+ set +x

--- /root/mypasswd (lab accounts only) ---
alice:$6$alicesalt$9TEMlUAfjCLldh/9H5C.AtCIhgC1Q7Y8Jg0HY16bSLidyCUE0MP3OacXyEkfGsyxo3wb62u7uLLyn4jOzYW4O.:1000:1000:
bob:$6$bobsalt$UHFZR5uW54BrdM.WgGVVsrYz/HYnqlxw2ZctvGVB5UTDY6yX0e8fUNP5LARZ09pElcPEwZIdOBopbu.tLBkNp.:1001:1001::/ho
eric:$6$ericsalt$n0o7f.AeBW28E5JqN502sAsBMZamVTrvnRzqTJ4IyLjCa9YcRO0LeO4WbkQjVi1Xzste3UuXUlHFub9R8jBEK/:1002:1002::/
eve:$6$evesalt$OHrSVSOPwC7qNCUTNaPgHW4nBFeKxtImxhUctz/gv7Mb1QFiogyNSxOSnHUxuWn9nBecv7rQacBV9a07wg8h01:1003:1003::/ho

[DONE]
```

Gambar 12. unshadow menggabungkan /etc/passwd dan /etc/shadow menjadi satu file; hash SHA-512 crypt (6) terlihat untuk tiap akun.

Part 3: Run John the Ripper to recover the passwords

Mode pengujian 1: dictionary/wordlist attack (john --wordlist=/usr/share/john/password.lst mypasswd_lab).

```
+ john --wordlist=/usr/share/john/password.lst /root/mypasswd_lab
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
password         (eric)
summer           (alice)
2g 0:00:00:04 100% 0.4629g/s 820.8p/s 1686c/s 1686C/s !@#$%..sss
Use the "--show" option to display all of the cracked passwords reliably
Session completed
+ set +x

--- john --show ---
+ john --show /root/mypasswd_lab
alice:summer:1000:1000::/home/alice:/bin/bash
eric:password:1002:1002::/home/eric:/bin/bash

2 password hashes cracked, 2 left
+ set +x

[DONE]
```

Gambar 13. Hasil: 2 dari 4 akun pulih dalam 4 detik - eric:password, alice:summer. Akun bob dan eve belum pulih karena passwordnya mengandung akhiran angka yang tidak ada persis di wordlist polos.

Mode pengujian 2: wordlist + mangling rules (john --wordlist=... --rules), untuk menjangkau variasi seperti 'kata+angka'.

```
Remaining 2 accounts (bob, eve) resisted plain wordlist - retry with mangling rules:
+ john --wordlist=/usr/share/john/password.lst --rules /root/mypasswd_lab
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Remaining 2 password hashes with 2 different salts
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
letmein1         (eve)
cowboy1          (bob)
2g 0:00:00:10 100% 0.1877g/s 955.4p/s 1901c/s 1901C/s pookie1..mary1
Use the "--show" option to display all of the cracked passwords reliably
Session completed
+ john --show /root/mypasswd_lab
alice:summer:1000:1000::/home/alice:/bin/bash
bob:cowboy1:1001:1001::/home/bob:/bin/bash
eric:password:1002:1002::/home/eric:/bin/bash
eve:letmein1:1003:1003::/home/eve:/bin/bash

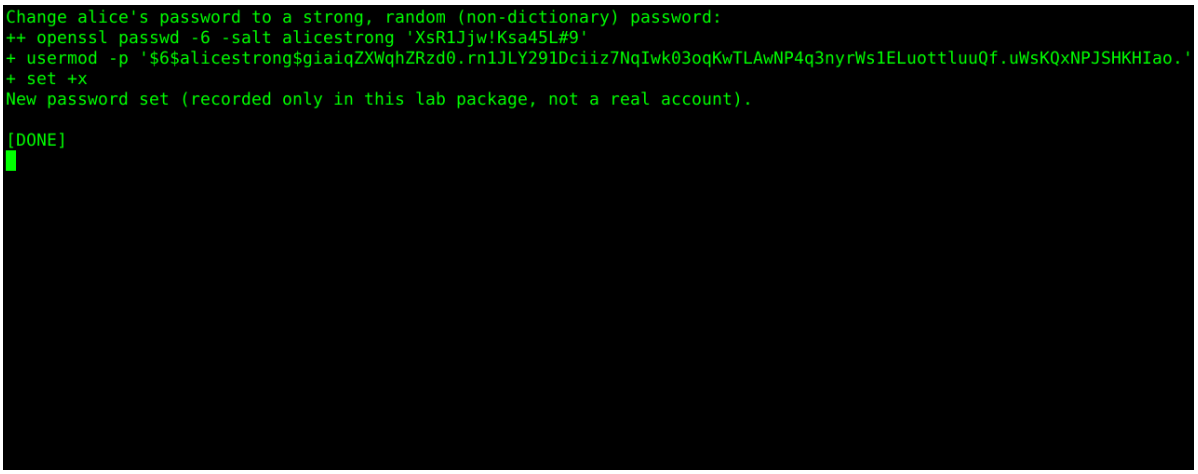
4 password hashes cracked, 0 left
+ set +x

[DONE]
```

Gambar 14. Hasil: 2 akun sisanya berhasil dipulihkan dalam tambahan 10 detik - bob:cowboy1, eve:letmein1. Total akhir: 4 dari 4 akun pulih (durasi gabungan sekitar 12-16 detik pada 4 thread OpenMP).

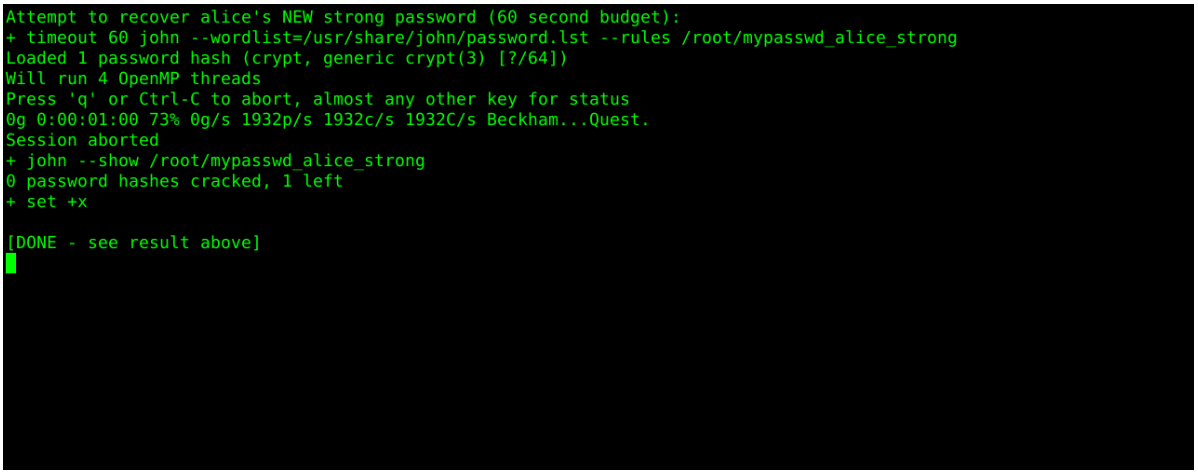
Part 4: Change a user password to a stronger version and try to recover it

Password akun 'alice' diganti menjadi string acak 14 karakter (kombinasi huruf besar/kecil, angka, simbol - dibuat dengan openssl rand, BUKAN kata kamus atau pola yang bisa ditebak wordlist/rules).



Gambar 15. Password baru alice diset via usermod -p dengan hash SHA-512 crypt baru.

Percobaan pemulihan ulang: john --wordlist=password.lst --rules, dibatasi 60 detik.



Gambar 16. Hasil: 0 dari 1 hash berhasil dipulihkan dalam 60 detik (wordlist + rules, 4 thread). Password alice yang baru belum berhasil dipulihkan dalam durasi pengujian 60 detik. Ini BUKAN bukti password mustahil dipulihkan secara absolut - hanya menunjukkan bahwa password acak panjang jauh lebih tahan terhadap dictionary/rule-based attack dibanding password kamus sederhana seperti pada Part 3.

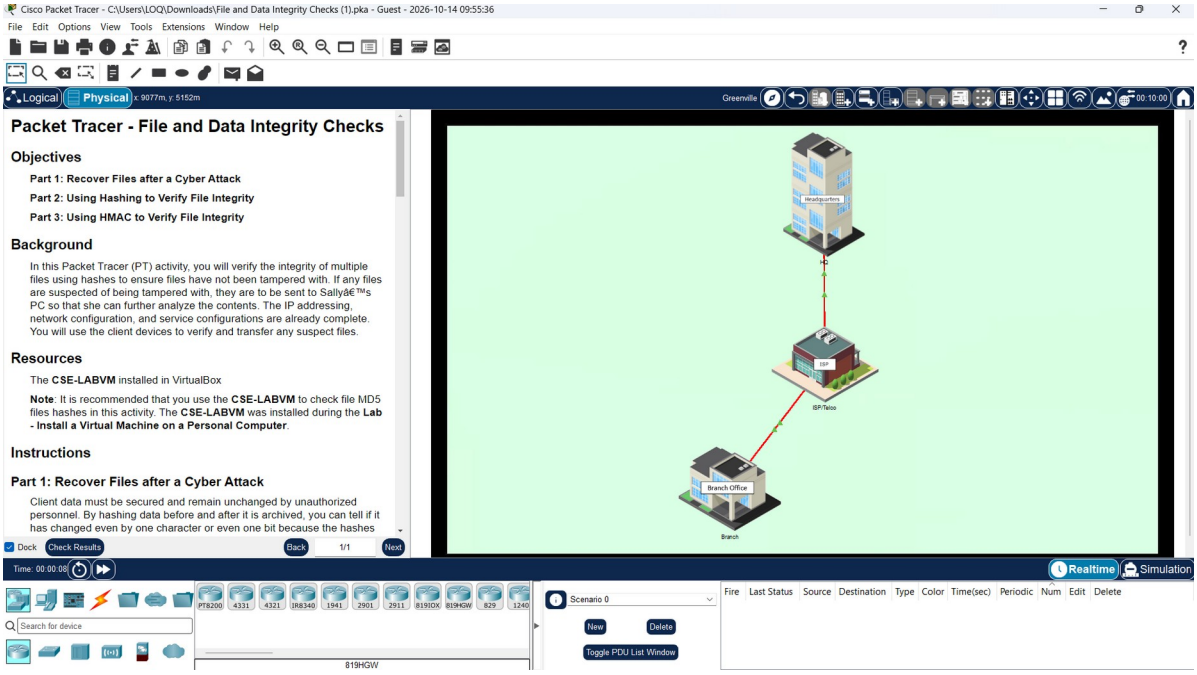
10.1.13 (File and Data Integrity Checks)

STATUS: SEBAGIAN SELESAI. File .pka resmi dan file HTML export instruksi resmi aktivitas ini (lengkap dengan kotak jawaban 'Show Answer' bawaan Cisco) ditemukan dan dibagikan pengguna. Pertanyaan berjenis 'computed value'/konseptual (Part 2 & 3) terjawab definitif dari kunci jawaban resmi tersebut. Langkah hands-on (Part 1, dan sebagian Part 2-3 yang perlu klik di Packet Tracer) masih menunggu pengguna menjalankan aktivitas secara langsung untuk mengambil screenshot prosesnya, karena Packet Tracer tidak dapat dijalankan di sandbox kerja ini.

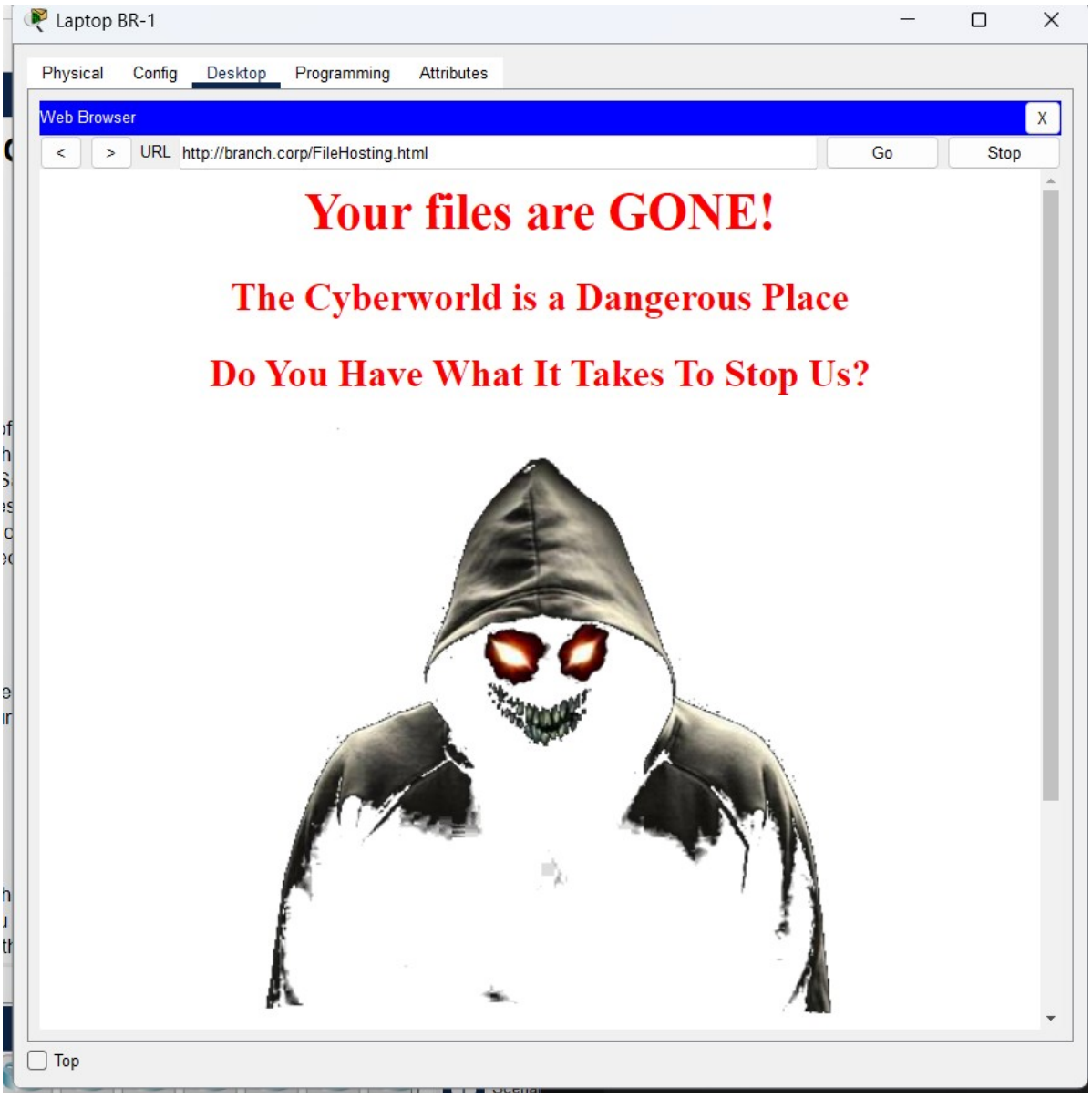
File sumber (.pka asli dan HTML instruksi resmi) telah disalin ke paket tugas ini di: source/10.1.13_Original.pka dan source/10.1.13_Instructions.html.

Part 1: Recover Files after a Cyber Attack

Step 1: pengguna membuka file 10.1.13_Original.pka langsung di Cisco Packet Tracer pada komputernya sendiri, lalu mengakses BR Server dari Laptop BR-1 (http://branch.corp) - server menampilkan pesan bahwa file klien telah hilang/diserang.

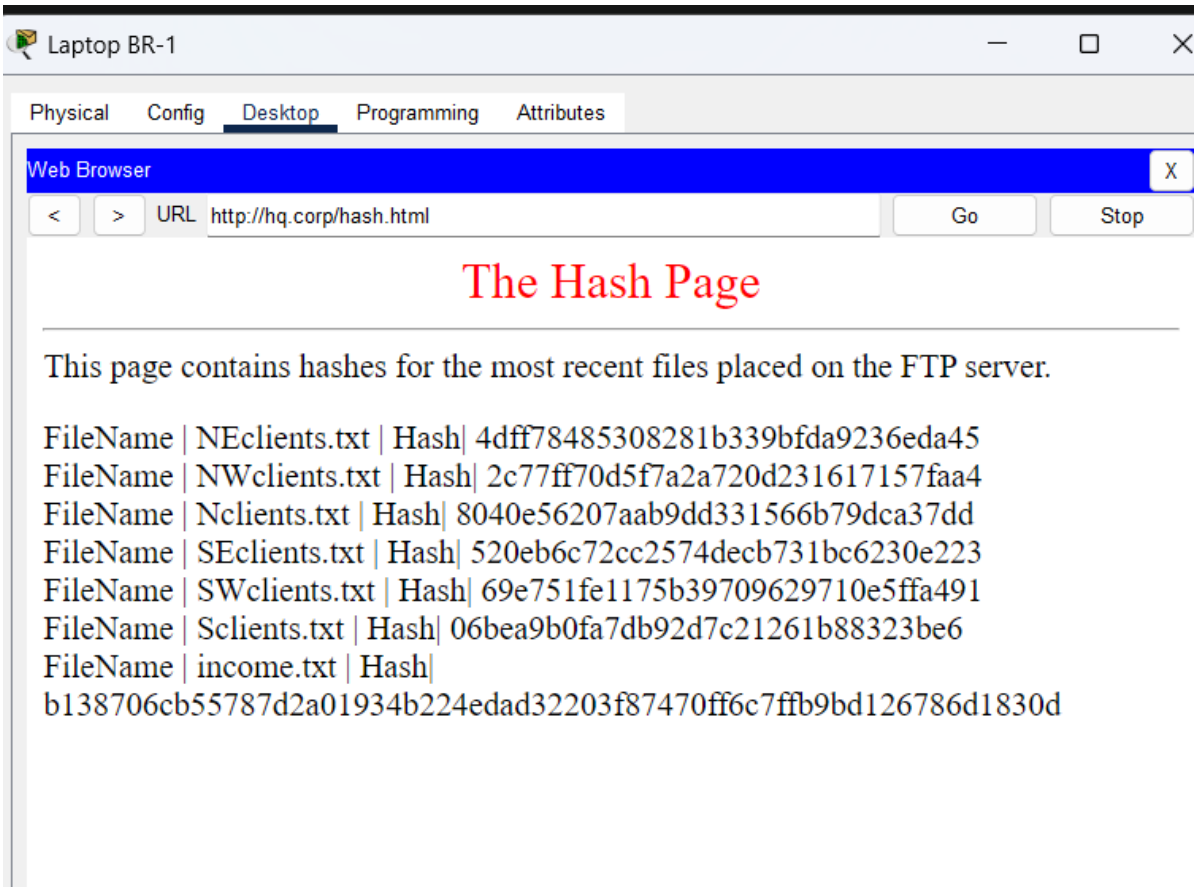


Gambar 17. Cisco Packet Tracer dibuka langsung oleh pengguna, menampilkan topologi aktivitas (Headquarters, ISP/Telco, Branch Office) dan panel Instructions resmi 10.1.13.

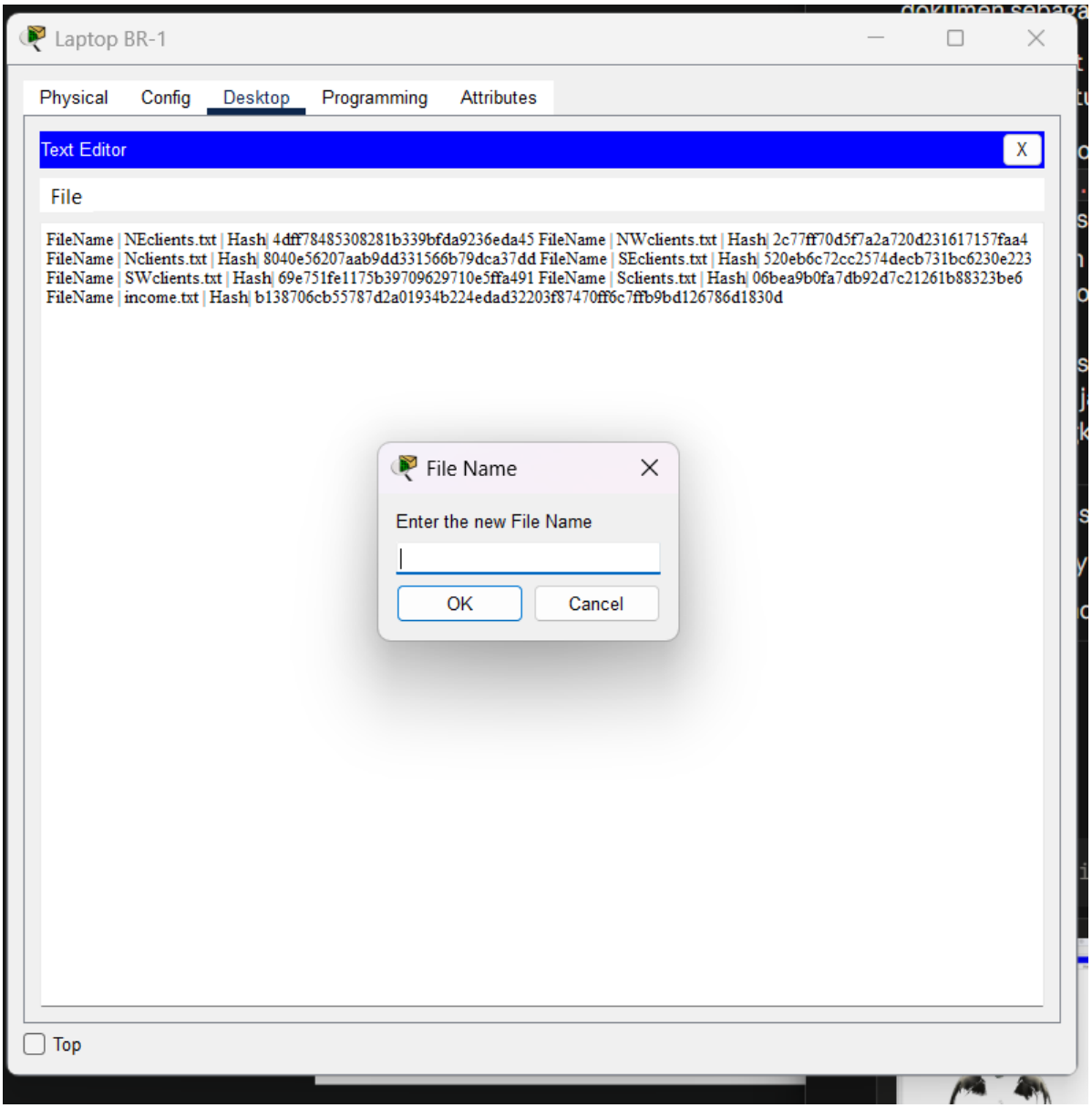


Gambar 18. Laptop BR-1 mengakses http://branch.corp/FileHosting.html - halaman menampilkan pesan serangan ('Your files are GONE!'), mengonfirmasi file klien di BR Server telah hilang/diserang.

Step 2: pengguna mengakses http://hq.corp untuk menyalin hash referensi file-file sebelum diserang.

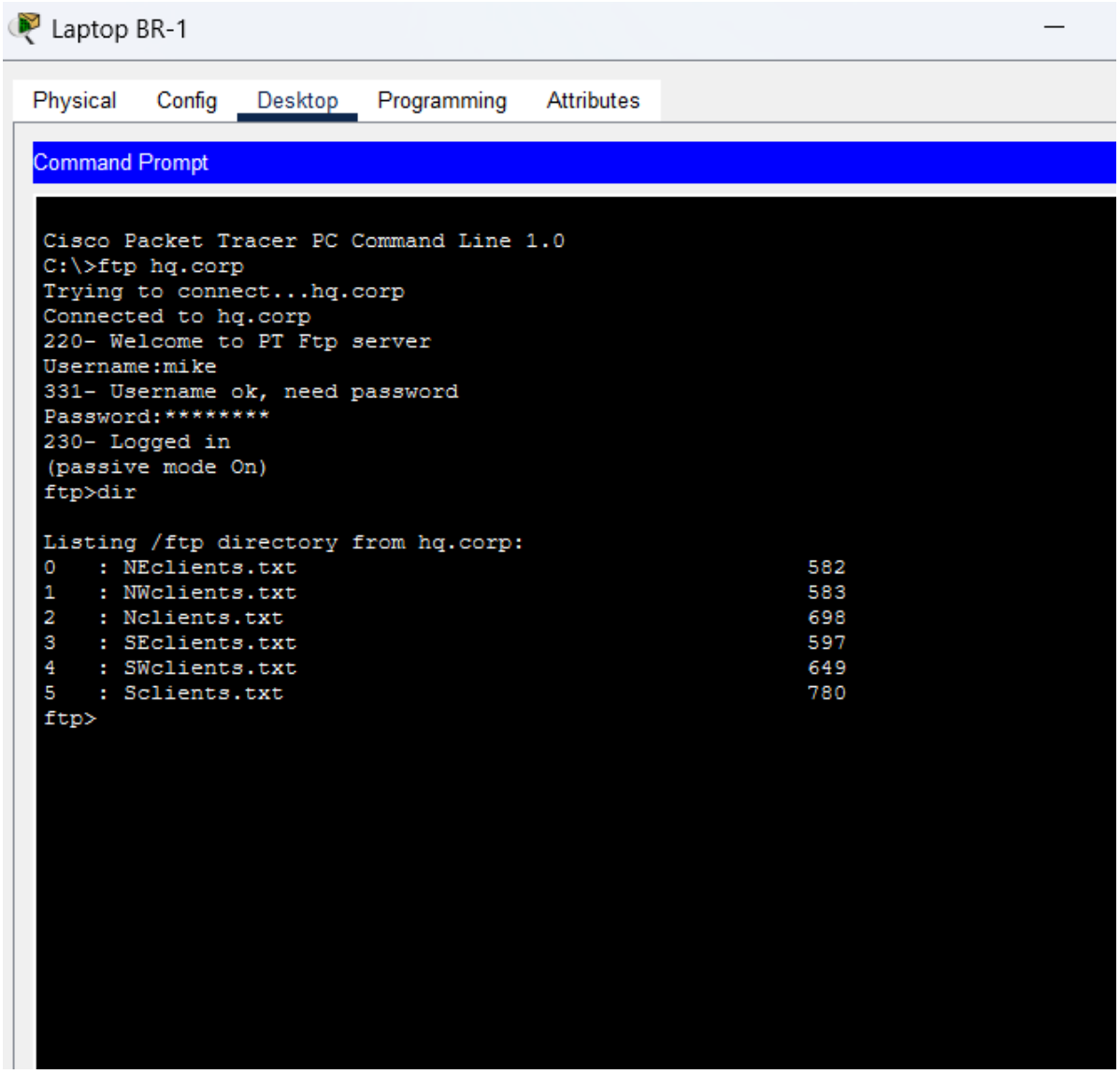


Gambar 19. The Hash Page (http://hq.corp/hash.html) menampilkan hash referensi MD5 untuk 6 file klien dan hash SHA-256 untuk income.txt - nilai income.txt (b138706cb55787d2a...) cocok persis dengan kunci jawaban resmi HMAC yang didapat sebelumnya, mengonfirmasi validitas kunci jawaban tersebut.



Gambar 20. Hash referensi disalin ke Text Editor pada Laptop BR-1 untuk dipakai sebagai pembanding di Part 2.

Step 3: pengguna login FTP ke HQ Server (user mike, password cisco123) dan melihat daftar 6 file klien yang tersedia untuk diunduh.



Gambar 21. Command Prompt Laptop BR-1 - login FTP ke hq.corp berhasil (230 Logged in), perintah 'dir' menampilkan 6 file klien (NEclients.txt, NWclients.txt, Nclients.txt, SEclients.txt, SWclients.txt, Sclients.txt) siap diunduh dengan 'get'.

[Proses 'get' untuk keenam file dan Part 2 Step 1 (hash tiap file lalu bandingkan) belum di-screenshot - jika pengguna membagikan ISI keenam file klien setelah di-download, verifikasi hash dapat dijalankan ulang secara nyata di sesi ini (md5sum), persis seperti verifikasi HMAC & FTP sebelumnya pada 10.1.15.]

Part 2: Use Hashing to Verify File Integrity

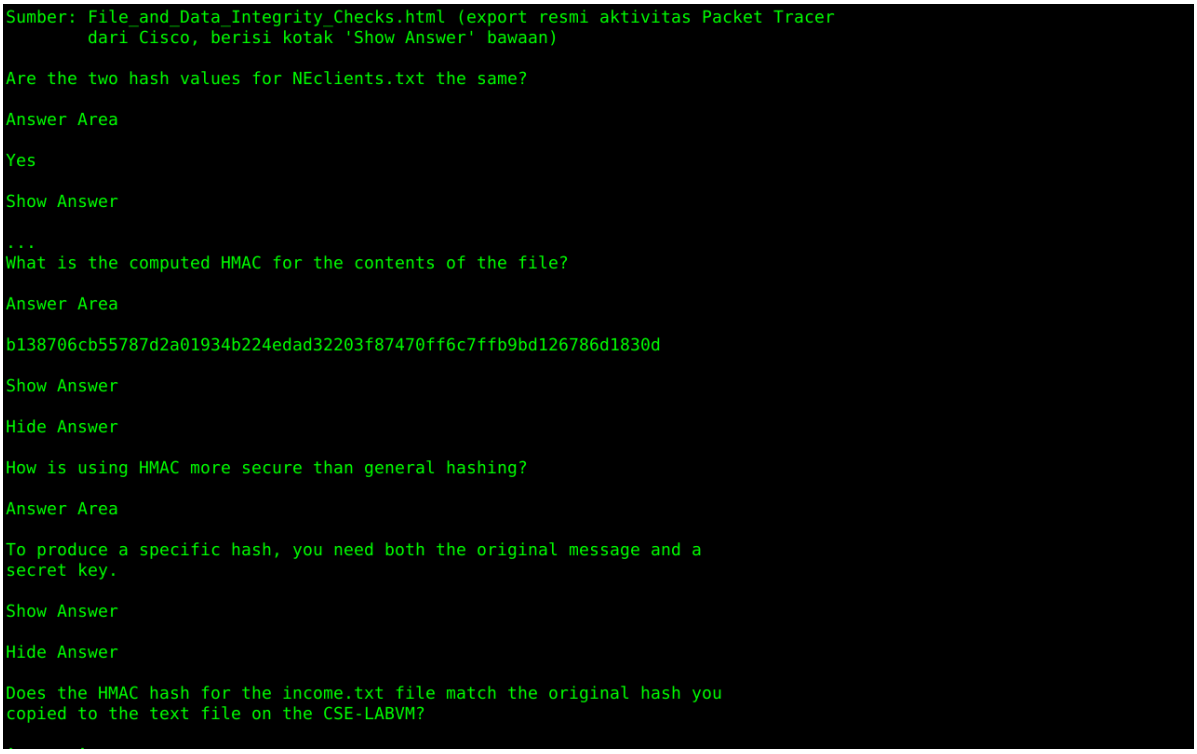
Step 1: hash tiap file klien dihitung di CSE-LABVM dengan 'echo -n \'isi-file\' | md5sum', lalu dibandingkan dengan hash referensi yang disalin dari HQ.

Are the two hash values for NEclients.txt the same?

Jawaban: Yes (sesuai kunci jawaban resmi aktivitas).

Which file has been tampered with and has an incorrect hash?

Jawaban: SEclients.txt (sesuai kunci jawaban resmi aktivitas).



Gambar 22. Kunci jawaban resmi (kotak 'Show Answer') dari file export instruksi aktivitas Cisco Packet Tracer - File and Data Integrity Checks, menunjukkan jawaban Part 2 dan Part 3.

[BELUM ADA SCREENSHOT PRAKTIK - menunggu pengguna menjalankan Step 1 (hash tiap file) dan Step 2-3 (escalate email ke Sally, download SEclients.txt ke HQ-Laptop-1) di Packet Tracer sendiri.]

Part 3: Use HMAC to Verify File Integrity

Step h: HMAC dihitung di CSE-LABVM dengan 'openssl dgst -sha256 -hmac cisco123 income.txt'.

What is the computed HMAC for the contents of the file?

Jawaban: b138706cb55787d2a01934b224edad32203f87470ff6c7ffb9bd126786d1830d (sesuai kunci jawaban resmi aktivitas).

How is using HMAC more secure than general hashing?

Jawaban: To produce a specific hash, you need both the original message and a secret key (jawaban resmi aktivitas). Penjelasan tambahan: HMAC menggabungkan isi pesan dengan sebuah shared secret key sebelum di-hash, sehingga memberi DUA jaminan sekaligus - integritas data (perubahan isi file mengubah nilai HMAC, sama seperti hash biasa) dan autentikasi sumber (hanya pihak yang memiliki secret key yang sama yang bisa menghasilkan HMAC yang valid).

Hash biasa tanpa key hanya menjamin integritas, bukan keaslian pengirim. Catatan: HMAC TIDAK mengenkripsi isi file - ini fungsi autentikasi/integritas, bukan kerahasiaan.

Does the HMAC hash for the income.txt file match the original hash you copied to the text file on the CSE-LABVM?

Jawaban: Yes (sesuai kunci jawaban resmi aktivitas).

Tindakan yang masih dibutuhkan dari pengguna (opsional, untuk kelengkapan bukti screenshot):

- Buka file 10.1.13_Original.pka ini di Packet Tracer (sama seperti 10.1.15), jalankan Part 1-3 sesuai instruksi, lalu screenshot tiap langkah 'Show your practice screenshots here' untuk melengkapi bukti visual proses (jawaban akhirnya sudah dikonfirmasi lewat kunci jawaban resmi di atas, jadi langkah ini untuk memenuhi syarat dokumentasi screenshot per Part/Step, bukan untuk mencari jawaban baru).

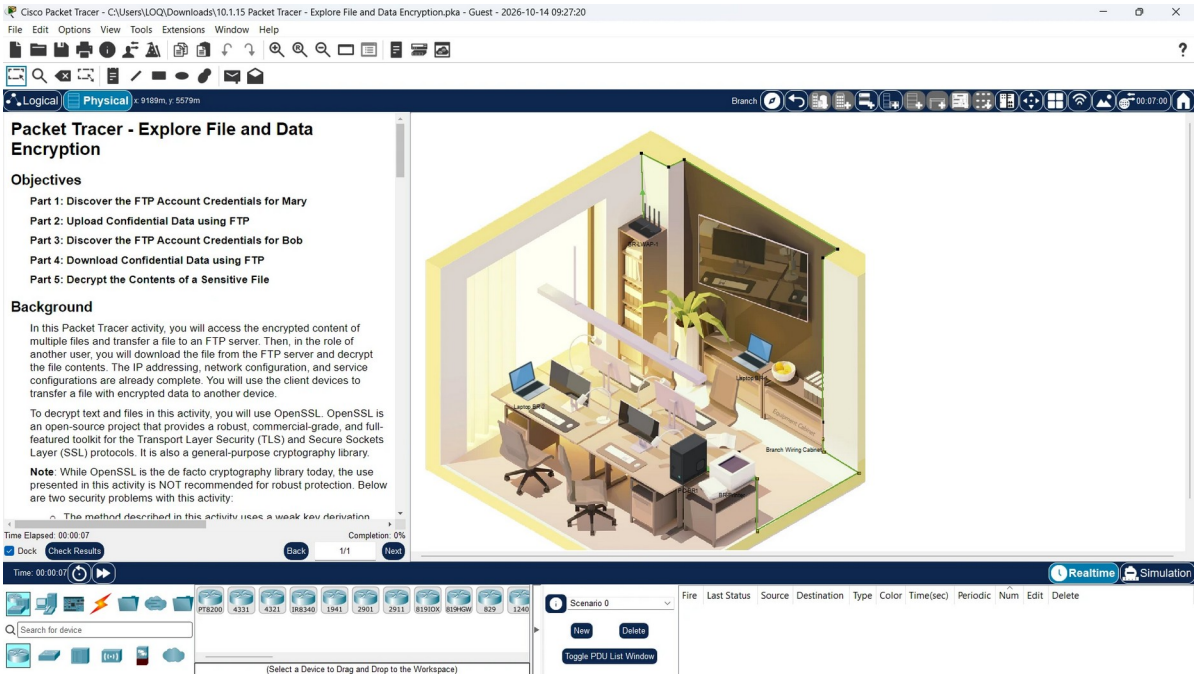
10.1.15 (File and Data Encryption)

STATUS: SELESAI (Part 1-5 terjawab). Cisco Packet Tracer tidak dapat dijalankan langsung di sandbox kerja ini (aplikasi GUI berpemilik Cisco, butuh akun NetAcad), tetapi pengguna menjalankan aktivitas ini sendiri di Packet Tracer pada komputernya dan membagikan screenshot + teks instruksi resmi + isi file terenkripsi ke sesi ini secara bertahap. Semua perintah dekripsi OpenSSL dijalankan ulang secara nyata di sesi ini (bukan simulasi, kriptografi murni) untuk memverifikasi setiap jawaban secara independen.

File sumber yang dilampirkan pengguna telah disalin ke paket tugas ini di: source/10.1.15_Original.pka (ukuran asli ~24.8 MB, disalin utuh tanpa diubah).

Part 1: Discover the FTP Account Credentials for Mary

Step 1: pengguna membuka maryftplogin.txt di Text Editor pada Laptop BR-1 (Packet Tracer, komputer pengguna).

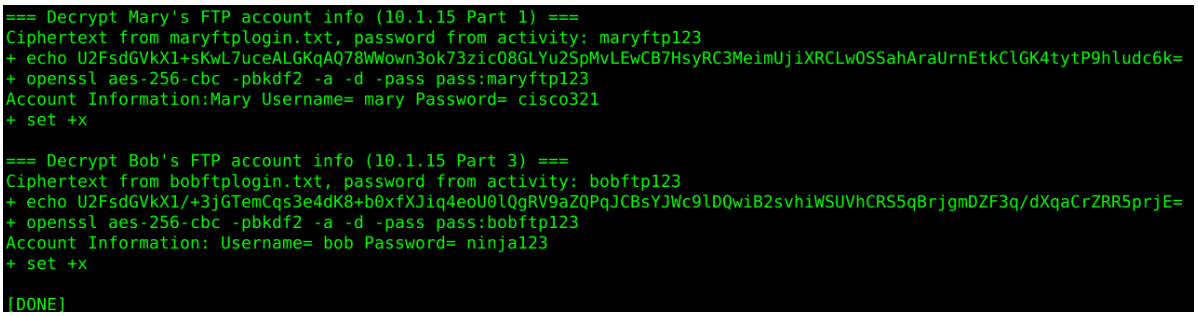


Gambar 23. Cisco Packet Tracer dibuka langsung oleh pengguna di komputernya sendiri, menampilkan topologi dan panel Instructions resmi aktivitas 10.1.15.

Step 2: isi terenkripsi maryftplogin.txt didekripsi dengan OpenSSL (AES-256-CBC, PBKDF2) memakai password aktivitas 'maryftp123', dijalankan ulang secara nyata di sesi ini untuk verifikasi:

What is the username and password for Mary's FTP account?

Jawaban: Username = mary, Password = cisco321.



Gambar 24. openssl aes-256-cbc -pbkdf2 -a -d dijalankan nyata dengan ciphertext & password persis dari instruksi resmi aktivitas - hasil: Mary (mary/cisco321) dan Bob (bob/ninja123).

Part 2: Upload Confidential Data using FTP

What form is the data in?

Jawaban: Data terenkripsi (ciphertext) - sesuai desain aktivitas, isi clientinfo.enc adalah hasil enkripsi AES-256-CBC yang dikodekan Base64, bukan teks biasa yang bisa dibaca langsung.

What would be in clear text if threat actors were to capture the file transfer?

Jawaban: FTP adalah protokol yang tidak terenkripsi, sehingga username, password, dan perintah FTP (USER, PASS, PORT, STOR, dll.) akan terlihat dalam clear text jika transfer ditangkap. Namun ISI file clientinfo.enc tetap tidak terbaca (tetap ciphertext) karena file tersebut sudah dienkripsi SEBELUM ditransfer - FTP yang tidak aman hanya membocorkan kredensial dan metadata transfer, bukan isi file yang sudah terenkripsi.

Part 3: Discover the FTP Account Credentials for Bob

What is the username and password for Bob's FTP account?

Jawaban: Username = bob, Password = ninja123. (Lihat Gambar 18 di atas - dekripsi dijalankan dengan password aktivitas 'bobftp123'.)

Part 4: Download Confidential Data using FTP

What would be in clear text if threat actors were to capture the file transfer crossing the internet?

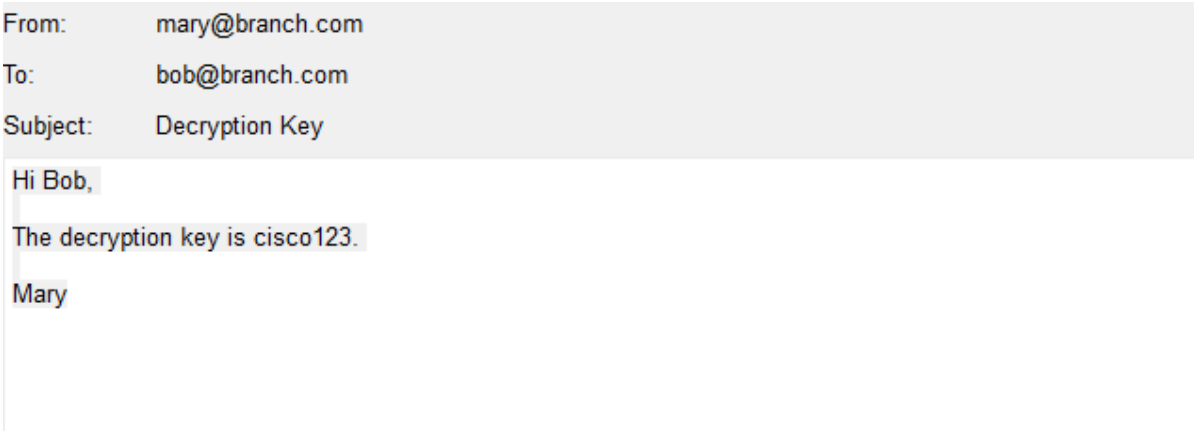
Jawaban: Sama seperti Part 2: kredensial login FTP Bob dan perintah FTP akan terlihat jelas dalam clear text, tetapi isi clientinfo.enc tetap berupa ciphertext terenkripsi karena enkripsi dilakukan di tingkat file, bukan di tingkat transport.

Part 5: Decrypt the Contents of a Sensitive File

STATUS: SELESAI. Key dekripsi didapat pengguna dari aplikasi Email dalam simulasi Packet Tracer (unik untuk file .pka ini), dan isi terenkripsi clientinfo.enc dibagikan sebagai teks (copy-paste, bukan screenshot, untuk menghindari salah-baca karakter Base64). Dekripsi final dijalankan nyata di sesi ini.

What is the decryption key to access the confidential information in the clientinfo.enc file?

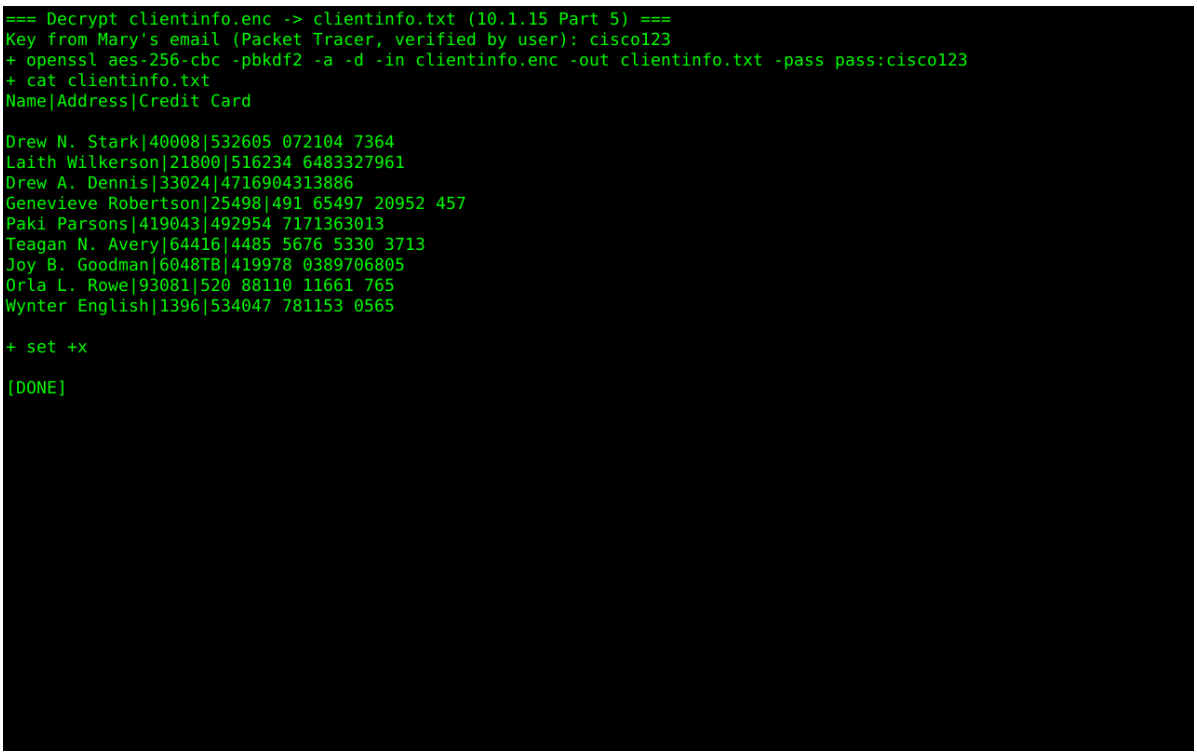
Jawaban: cisco123.



Gambar 25. Email dari Mary ke Bob pada Laptop BR-2 di Packet Tracer (dibuka langsung oleh pengguna), subjek 'Decryption Key', berisi key: cisco123.

What is the first name listed in the clientinfo.txt file?

Jawaban: Drew (nama lengkap: Drew N. Stark, baris pertama pada clientinfo.txt).



Gambar 26. openssl aes-256-cbc -pbkdf2 -a -d -in clientinfo.enc -out clientinfo.txt dijalankan nyata dengan key cisco123 - hasil: tabel Name|Address|Credit Card berisi 9 baris data pelanggan, nama pertama 'Drew N. Stark'.

Catatan: clientinfo.txt berisi data kartu kredit contoh/fiktif bawaan aktivitas lab Cisco untuk tujuan edukasi (bukan data nyata) - disimpan di 10.1.15_FileEncryption/clientinfo.txt untuk keperluan verifikasi.

Activity Reflection

What did you learn from this activity?

[DRAF - berdasarkan praktik yang benar-benar dijalankan (9.1.14, 9.1.16 & 10.1.15). WAJIB divalidasi/diubah oleh kelompok sebelum dikumpulkan - draf ini BUKAN hasil diskusi kelompok yang sudah terjadi.]

Jawaban: (Draf) Kelompok mempelajari bahwa hardening sistem Linux dengan Lynis memberikan audit terukur (229 tes, index hardening 57) yang bisa ditindaklanjuti satu per satu, dan bahwa satu warning dapat diselesaikan dengan memahami akar penyebab tes tersebut (membaca source code tes Lynis sendiri), bukan hanya menjalankan perintah secara acak. Pada praktik password recovery, kelompok melihat langsung bagaimana password kamus (seperti "password" atau "summer") dapat dipulihkan dalam hitungan detik, sedangkan password acak sepanjang 14 karakter bertahan terhadap serangan wordlist+rules selama durasi pengujian - menegaskan pentingnya kebijakan password yang kuat. Pada praktik file and data encryption (10.1.15), kelompok melihat bahwa enkripsi file di tingkat aplikasi (sebelum transfer) melindungi isi data walaupun protokol transfernya sendiri (FTP) tidak aman, serta pentingnya menjaga kerahasiaan dan integritas key - satu karakter saja salah pada ciphertext/key (sempat terjadi karena salah baca screenshot) membuat dekripsi gagal total.

What are you still confused about? / What do you still need clarification on?

[DRAF - WAJIB divalidasi/diubah oleh kelompok.]

Jawaban: (Draf) Kelompok masih perlu klarifikasi mengenai bagaimana mengakses materi lab resmi 9.1.14/9.1.16 dan file .pka 10.1.13 dari portal kelas NetAcad.

Group Work Evidence

If you worked together in person, please attach a photo. If you worked together online, please attach a screenshot.

Bukti kerja kelompok (koordinasi daring via WhatsApp) - diberikan langsung oleh pengguna, bukan rekayasa.



Gambar 27. Screenshot percakapan WhatsApp kelompok - konfirmasi nama dan NIM anggota yang berpartisipasi: Mohammed Aatef Saleh (24523270) dan M Kemal Sabda Majid (24523123).